Task 1: STRIDE Threat Model & Risk Register

1. System Assets

- **A1:** Passwords, tokens, session cookies (Secret)
- **A2:** Salary, bank account, national ID (Restricted)
- **A3:** Personal details (name, phone, address, date of birth, email) (Confidential)
- **A4:** Payroll runs, ledger, invoices, expenses (Restricted - Integrity Critical)
- **A5:** Audit logs (Integrity Critical)
- **A6:** AI models, prompts and chat history (Confidential)
- **A7:** Signing keys, encryption keys, API keys (Secret)
- **A8:** Source code, pipeline and registry images (Confidential)

2. Trust Boundaries Mapped

- **TB1 (Internet <-> Proxy):** Untrusted public internet to the reverse proxy entrance.
- **TB2 (Proxy <-> Apps):** Terminated traffic entering the internal Next.js Portal and Python Backend.
- **TB3 (Apps <-> Data):** Backend API reading/writing to PostgreSQL and Redis.
- **TB4 (Backend <-> AI/Analytics):** Backend routing sensitive payroll features to AI and Analytics services.
- **TB5 (Dev <-> Prod Pipeline):** Developer workstations pushing code and images through CI to the live system.

3. Risk Register (30 STRIDE Threats)

Scoring Formula: Likelihood (1-5) x Impact (1-5). Bands: 1-6 Low, 7-12 Medium, 13-19 High, 20-25 Critical.

ID	STRIDE	Affected Component	Threat Description	L	I	Score
TR-01	Spoofing	C3 Portal	An attacker could brute-force weak employee passwords...	4	4	16
TR-02	Spoofing	C4 Backend	An attacker could forge or replay stolen session cookies...	3	5	15
TR-03	Spoofing	C8 Redis	An attacker on the local network could connect to unauthenticated Redis...	3	4	12
TR-04	Spoofing	C11 Dev Work	An attacker could compromise a developer laptop without 2FA...	2	5	10
TR-05	Spoofing	C5 AI Service	An attacker could spoof internal service headers...	3	4	12
TR-06	Tampering	C4 Backend	An attacker could manipulate unvalidated parameters...	2	5	10
TR-07	Tampering	C7 PostgreSQL	An attacker exploiting SQL injection in the reporting module...	2	5	10
TR-08	Tampering	C9 CI/CD	An attacker with repo access could tamper with pipeline build scripts...	2	5	10
TR-09	Tampering	Internal Net	An attacker performing ARP spoofing on unencrypted internal traffic...	2	4	8

ID	STRIDE	Affected Component	Threat Description	L	I	Score
TR-10	Tampering	C5 AI Service	An attacker could inject poisoned training data...	2	3	6
TR-11	Repudiation	C4 Backend	A rogue finance admin could execute off-cycle payroll runs...	3	5	15
TR-12	Repudiation	C10 Central	An attacker gaining admin access could delete or alter Postgres audit tables...	2	5	10
TR-13	Repudiation	C4 Backend	An employee could approve high-value expense reports without non-repudiation...	3	3	9
TR-14	Repudiation	C5 AI Chat	A user could send abusive or data-exfiltrating prompts...	3	2	6
TR-15	Info Disclosure	C4 Backend	An attacker could change the employee ID in a GET request (IDOR)...	4	5	20
TR-16	Info Disclosure	Internal Net	An attacker sniffing unencrypted internal plaintext traffic...	3	5	15
TR-17	Info Disclosure	C5 AI Chat	An attacker could use prompt injection techniques...	4	4	16
TR-18	Info Disclosure	C10 Central	Developers could log full HTTP request bodies containing raw passwords...	4	4	16
TR-19	Info Disclosure	C12 Backups	An attacker could access unencrypted database backup volumes...	2	5	10
TR-20	Info Disclosure	C6 Analytics	An attacker could tamper with dashboard iframe signed URLs...	3	3	9
TR-21	DoS	C2 Proxy	An external botnet could flood port 443 with volumetric HTTP requests...	4	4	16
TR-22	DoS	C4 Backend	An attacker could trigger bulk concurrent PDF payslip generation jobs...	4	3	12
TR-23	DoS	C8 Redis	An authenticated user could flood the Redis queue with junk background jobs...	3	3	9
TR-24	DoS	C7 PostgreSQL	An attacker could execute unindexed, complex analytics queries...	3	4	12
TR-25	DoS	C5 AI Service	An attacker could spam long context-length inputs to the AI service...	4	3	12
TR-26	Elevation	C4 Backend	An attacker could alter their JWT user role or claim...	3	5	15
TR-27	Elevation	C3 Portal	An attacker could exploit an SSRF vulnerability in the Next.js portal...	2	5	10
TR-28	Elevation	C9 CI Pipeline	An attacker submitting a malicious pull request could execute arbitrary scripts...	3	5	15
TR-29	Elevation	C8 Redis	An attacker exploiting Redis deserialization flaws...	2	5	10
TR-30	Elevation	C5 AI Assistant	An attacker could leverage tool-use / function-calling prompt injection...	3	4	12

4. Top 10 Threats (Ranked)

1. **TR-15 (Score: 20 — Critical):** IDOR on payslip endpoints leaking salary data.

2. **TR-17 (Score: 16 — High):** AI Prompt injection exposing backend secrets.
3. **TR-18 (Score: 16 — High):** Cleartext logging of passwords and tokens.
4. **TR-01 (Score: 16 — High):** Password brute-forcing on the login portal.
5. **TR-21 (Score: 16 — High):** Volumetric DoS on the Reverse Proxy.
6. **TR-26 (Score: 15 — High):** JWT Role manipulation (Privilege Escalation).
7. **TR-16 (Score: 15 — High):** Network sniffing of unencrypted internal traffic.
8. **TR-02 (Score: 15 — High):** Session token hijacking for admin impersonation.
9. **TR-11 (Score: 15 — High):** Unlogged off-cycle payroll runs (Repudiation).
10. **TR-28 (Score: 15 — High):** Malicious pull requests stealing CI/CD secrets.